Fix Pack: Business Brief

Fabricio Rodriguez

October 25, 2026

CONTENTS

Fix Pack: Business Brief for a Co-Founder 3

1. The one-page version 3
2. The problem in business terms 3
3. The product 4
4. Who pays: two guesses to test 5
5. Competition 6
6. How we would make money 6
7. How we would sell it 7
8. Risks and what could kill this 8
9. Exit possibilities 8
10. What I need from you 9
11. Next 30 days 10
12. Honest limits of this report 10

Fix Pack: Business Brief for a Co-Founder

Prepared October 25, 2026. Plain-language summary of a full research report. Nothing here has been tested with a real customer yet.

1. The one-page version

What we would sell. We fix a specific security bug in a customer's software, prove the fix works, and hand over a one-page sheet showing the proof. We charge per fix. We call each one a **Fix Pack**.

Why now. AI tools now find software security bugs far faster than people can repair them. This month a flaw called PHP2Shell hit PHP, the programming language behind roughly 70% of websites. Anthropic's Project Glasswing found over 10,000 serious bugs in about a month, yet only about 6% of the ones reported to maintainers had been fixed by May.

Where the gap is. Finding bugs is crowded and heavily funded. Fixing them safely, with proof, is slow and mostly unserved.

What we are asking you to do. Help us find out, within 30 days, whether anyone will pay for this. The technical part is mine. The market, pricing, selling and legal questions are where I need you.

What we do not know yet. Whether anyone will pay enough per job to cover our time. This is the single biggest risk, and no evidence in this report answers it.

2. The problem in business terms

Think of a building inspector who finds 10,000 code violations in a month, while the city has a handful of contractors to fix them. Inspection has become cheap. Repair is now the bottleneck.

Three facts show it:

- Only about 97 of 1,596 reported Glasswing findings were confirmed patched by May 22 (CSA research note).
- The curl project, a widely used open-source tool, shut down its bug bounty after being flooded with low-quality AI reports.
- HackerOne paused its Internet Bug Bounty in March because fixing, not finding, had become the bottleneck.

A second, smaller problem: when a customer's software runs on an outdated version of its programming language, there may be no official patch at all. That is what happened to some PHP users this month.

3. The product

A Fix Pack is one finding in, one proven fix out.

Step	What happens	What the customer sees
1. Intake	Customer shares the app and the finding (a scanner result, a pentest item, or a CVE, which is a public bug ID)	A short form
2. Reproduce	Our software runs the app in an isolated sandbox and demonstrates the bug. If we cannot reproduce it, we stop and charge nothing	A note: "we reproduced it" with the exact steps
3. Fix	Our AI writes the repair and a test that fails before the fix and passes after	A pull request (a proposed change they can accept or reject)
4. Prove	We run their existing tests and produce a one-page **evidence sheet**: what was wrong, proof, what changed, proof it is fixed	A PDF they can forward to a client, insurer or auditor
5. Merge	The customer decides whether to accept the change	Their only decision

The differentiator is the evidence sheet. Competitors send fixes. We send fixes plus a document that answers "how do I know it worked?"

For the first 90 days I review every fix personally before it goes out. Research shows automated security fixes from unknown bots are accepted only about 13% to 37% of the time, so a human name matters.

4. Who pays: two guesses to test

We are not sure who our first customer is. We want you to help test both.

Buyer A: web agencies and IT service firms. They maintain custom websites and apps for many small clients. They just scrambled over PHP2Shell. They already charge clients $99 to $349 a month for site maintenance. No funded competitor fixes their custom code. Weakness: they are price-sensitive, and many have no automated tests, which makes proving a fix harder.

Buyer B: a small software company with a blocked deal. Example: a 15-person software-as-a-service company whose customer demanded a penetration test (a hired security attack simulation). The test found a bug and the enterprise deal is stalled until it is fixed. They have a deadline, money at stake and a clear definition of done. This is probably the stronger buyer on paper.

Who we are not targeting. Small engineering teams that already use tools like MindFort ($499 a month), Corgea ($39 to $49 per developer), Aikido ($300 to $1,050 a month) or GitHub’s built-in fixes. That market is crowded.

5. Competition

Group	Examples	Funding	What they do	Why we are not competing head-on
Automated attack testing	XBOW, Horizon3, Armadin	$250M to $437M each	Find exploitable bugs	Too well funded; finding is not our job
Find and fix for companies	depthfirst, Pixee, Aisle	Tens to hundreds of millions	Send small automated fixes to security teams	Sold top-down to large teams; fixes are narrow
Find and fix for small teams	MindFort, Corgea, Aikido	Seed to $1B valuation	Scanner plus fix, $39 to $1,050 a month	Crowded price shelf
WordPress protection	Patchstack ($69 a month)	Small	Blocks known plugin bugs	Does not fix custom code
Extended PHP support	TuxCare, sold through web hosts	Mid	Patches old PHP versions	A real substitute for our upgrade idea
Free from the big platforms	GitHub Copilot Autofix, OpenAI Codex Security	n/a	Scan and autofix in the developer’s tools	The biggest long-term threat

Honest read: the large vendors serve customers with their own engineers. The customer with thirty client apps on five different software versions is poorly served. That is our opening, but it is unproven.

6. How we would make money

All prices are **my proposals, not tested numbers**.

Offer	What it is	Proposed price
Fix Pack	One bug fixed and proven	$400 to $1,500
Evidence sheet only	We verify and document someone else's fix	$150 to $300
Runtime upgrade	Move one app to a supported software version	$2,000 to $8,000 (weak: TuxCare competes)
Monthly retainer	Ongoing patching for all of an agency's apps	Do not offer yet

For comparison, a human penetration test for a startup costs $3,000 to $10,000 for one app. A retest costs $2,000 to $5,000.

Why the retainer is on hold. An agency that resells at double our $150 to $400 would charge clients $300 to $800, which is above the $99 to $349 clients pay today. The margin story does not work until we know our cost per job.

First sales approach. Three to five **paid** pilot jobs at a discount, each with a fixed scope and written acceptance test. Not free jobs. Free work tests free demand.

7. How we would sell it

1. **Free checker.** Many people think they are patched because their server reports a version number, but Linux systems patch without changing that number. A simple tool that checks properly gives us a reason to start conversations and collect emails.
2. **Ten conversations in 14 days.** Ask: What did you do the week of October 21? What did it cost? Who fixed it last time? Would you have paid for a proven fix?
3. **Channels.** Web hosts, agency communities, and distributors that sell to IT service firms, such as Pax8.
4. **Trust page.** Explain what our software can and cannot touch. Buyers vet security vendors before watching a demo.
5. **Public prices.** Many competitors hide them. Some publish, so this is a small advantage, not a unique one.

8. Risks and what could kill this

Risk	Why it matters	How we would know
Nobody pays enough	The central unknown	Fewer than 2 paid pilots in 30 days
Fixing costs us too many hours	Reconstructing a customer's app environment may take days	Hours per job during the pilot
Big platforms add this	GitHub or OpenAI could bundle it free	Quarterly check of their announcements
Customer blames us	We touch their code; a bad fix harms trust	Need a contract with liability limits and business insurance
The scare fades	PHP2Shell fear drops in weeks; exploitation is still disputed	Sell on lasting deadlines instead (below)
Extended support substitutes	TuxCare patches old PHP without migrating	Ask every prospect what they already use
A student's name is not assurance	We cannot present ourselves as an independent auditor	Position the sheet as documentation, not certification

Lasting deadlines that do not depend on the headline:

- PHP 8.2 security support ends December 31, 2026.
- The EU Cyber Resilience Act reporting duties started September 11, 2026, with full duties from December 2027. It applies to makers of products with digital elements, so it helps some customers but not all.
- Cyber insurers increasingly ask for documented patching deadlines and proof of closure. This is reported by brokers and vendors; we have not seen an insurer's own rulebook.

9. Exit possibilities

Security companies have recently bought small teams with a working fix engine:

- Aikido bought Root, an automated patching startup, in a deal estimated at $70M to $100M.
- Check Point bought the Deepchecks team for an estimated $10M to $20M.
- Cohere announced a deal to buy Aisle.
- OpenAI moved to acquire Promptfoo.

We do not know why these buyers paid what they did. The pattern suggests they wanted a working engine and a team. A realistic first goal is paying customers and proof that evidence sheets get accepted, not a sale.

10. What I need from you

Your roles, in order of importance:

1. **Customer discovery.** Run or join the ten conversations. You will be better than I am at this.
2. **Pricing.** Challenge my numbers. Tell me what a small agency or software company would actually pay.
3. **Contracts and insurance.** Find out what a services agreement and a business insurance policy (errors and omissions) would cost for work on client code.
4. **Outreach.** Draft the first message to agencies and software companies.
5. **Competitor watch.** Track GitHub, OpenAI, MindFort and Patchstack announcements monthly.

My roles: build and operate the fix engine, review every fix, write the evidence sheets.

11. Next 30 days

Week	Goal	Done when
1	Write one fixed-scope pilot offer and the interview script	Offer fits on one page, with price and acceptance test
1 to 2	Ten conversations across both buyer types	Notes on all ten, answers to the four key questions
2 to 3	Identify 3 to 5 pilot candidates	Written yes or no from each
3 to 4	Run the first paid pilot	One fix delivered, hours logged
4	Go or no-go decision	Two paid pilots, or stop and reframe

Stop rule. If neither buyer type produces at least two paying pilots in 30 days, we either change buyers or stop. We do not build more software first.

12. Honest limits of this report

- No customer has been interviewed. The buyer choice is a hypothesis.
- Prices are my proposals, anchored on competitor pricing, not tested.
- Many competitor figures come from vendor claims, news aggregators and third-party blogs. Funding and valuation numbers should be rechecked before any investor conversation.
- An independent reviewer, OpenAI's Codex, challenged the first draft. It found the market choice unvalidated, flagged a missed competitor (TuxCare), and corrected several overstated claims. All were accepted and fixed here.
- The full research report with every source is in the project repository under `docs/ideas/ai-security-service-validation.md`.